

AdvocateAuroraHealth

Title: AAH Server Security Integrated		Document Number: 2554
Document Type: ☒ Policy ☐ Procedure ☐ Guideline ☐ Other		Last Review/Revision Date: 06/24/2021
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 06/24/2024
		Effective Date: 06/24/2021
Scope: ☒ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name):		

I. PURPOSE

The purpose of this Policy is to provide minimum requirements for servers to ensure the protection of Advocate Aurora Health (AAH) Information and Information Resources.

II. SCOPE

This Policy applies to all Servers (including development, test existing in the environment longer than 48 hours, quality assurance, production, and disaster recovery servers). It also applies to the operating systems, applications, and databases that support Advocate Aurora Health, Inc. Information, and Information Resources.

III. DEFINITIONS/ABBREVIATIONS

Advocate Aurora Health: Advocate Aurora Health, Inc., and its affiliated entities.

Advocate Aurora Health Team Member: anyone employed by AAH who provides services on behalf of AAH. All AAH Team Members are expected to abide by AAH policies and procedures. All AAH Team Members are eligible to receive access to internal AAH systems, as required.

Advocate Aurora Health Information: All information that is owned by AAH or owned by third parties but provided to AAH. For clarification purposes only, information remains "AAH Information" even if it is in the possession and under the control of a third party (e.g., a third-party service provider and/or its subcontractors).

Advocate Aurora Information Resources: Any media, software, hardware, or other technology that supports the use, access, processing, storage, or transmission of AAH Information.

Business Impact Analysis (BIA): A process designed to identify critical business functions, determine the potential qualitative (non-financial) and quantitative (financial) impacts of a disruption in the business, and establish RTO and Recovery Point Objective targets.

Business Owner: A Team Member who sponsors a solution's creation or who has a business need for the solution.

Application Owner: A Team Member who is responsible for the application level technology aspects (e.g. implementation, maintenance, etc.) of a solution.

Infrastructure Owner: A Team Member who is responsible for the technical components of a HIT asset, such as a server.

Plan of Action & Mitigation (POAM): A documented series of steps to remediate or mitigate a specific vulnerability or set of vulnerabilities.

Privileged Accounts: Accounts which have elevated levels of access to servers or databases to manipulate or update the server or database, including information on the database or server.

Recovery Point Objective (RPO): The point in time (hours) which information used by an activity must be restored to enable the activity to operate on resumption.

Recovery Time Objective (RTO): The period of time within which infrastructure, applications, and/or functions must be recovered and accessible to the business following a disaster or business continuity event.

Restricted Information: AAH information that falls under Legally Restricted Confidential Information (Class 4), or AAH-Restricted Confidential Information (Class 3).

Server: A system (physical or virtual) device that provides access to a centralized resource or service across a network. This definition does not include containerization technologies.

System Administrator: A Team Member with privileged access to systems who provides information technology support for computing systems used for AAH purposes.

Vulnerability: A weakness in the design, implementation, operation, or internal control of a process that could expose the system to adverse threats from threat events.

IV. POLICY

Team Members installing, configuring, managing, and/or maintaining servers storing, processing, or transmitting AAH Information must adhere to the requirements in the Procedure of this Policy. There may be additional security controls required by individual departments to enhance the security of the AAH environment, in those cases, procedures and standards must be created to govern those controls.

Physical and virtual servers must be entered into AAH's Configuration Management Database (CMDB).

A. Installation

1. System Administrators must complete the following prior to installation:
 - a) Place servers in a physically secure location, either in an approved data center, secure data closet or an authorized cloud solution.
 - b) Disable the default restore capability. Domain controllers do not require disabling of the default restore capability.
 - c) Request a vulnerability assessment from IT Security and remediate vulnerabilities according to the schedule in the Vulnerability Management Standard prior to promoting to production.
 - d) Ensure logs are created as servers move through the creation and change processes.

B. Configuration

1. System Administrators must use the standard server image which must include the following:
 - a) Remove, disable, or change accounts and passwords according to the Electronic Systems Account Management Policy and AAH Password Requirements Appendix.
 - b) Ensure that accounts with access to the server meet applicable requirements in the Electronic Systems Account Management Policy and AAH Password Requirements Appendix.

- c) Ensure the server meets security requirements minimally including the below:
- d) Ensure supported operating system with security patches installed and activated.
- e) Install AAH approved Antivirus software and ensure the software is activated Enable host-based firewall for all newly configured servers.
- f) Enable web traffic for web servers.
- g) Encrypt web traffic for web servers.
- h) Disable unneeded services.
- i) Set up servers in an environment with appropriately restricted network access.
- j) Configure non-removable drives with access control.
- k) Document external network requirements and review them with HIT Security.
- l) Synchronize server clocks with an AAH approved network time protocol.
- m) Create data validation controls (e.g. only allow birthdays) on any data input into the server.
- n) Configure externally exposed servers that store, process or transmit Restricted Information with appropriate real-time OS/application logging. These logs must be provided to the Security Information and Event Management (SIEM).

C. Vulnerability Management

1. System Administrators must:

- a) Perform a vulnerability assessment, prior to the server being moved to production, as detailed by Vulnerability Management Standard.
- b) Create a Plan of Action & Mitigation (POAM) to remediate or mitigate the identified vulnerability(ies) prior to moving the server to production use.

D. Maintenance

1. System Administrators must:
 - a) Document a maintenance process to update servers with server and operating systems patches according to the Patch Management Standard. This process must be integrated with the overall server maintenance process and in collaboration with the HIT and Business Owners. The maintenance process should include a timetable for routine application of patches and patch clusters based on patch criticality and the server environment in accordance with the Vulnerability Management Standard.
 - b) Follow a detailed change management process to record planned and actual production changes to the server.
 - c) Ensure vulnerability assessments are conducted as required by the Vulnerability Management Standard.
 - d) IT Security Team Members are authorized to perform vulnerability scans on any server in the network.
 - e) Provide authorized credentials to HIT Security for Credential Scans, or install an agent on the device.
 - f) Modifications to the standard build of a server in accordance with its application must be done to comply with AAH IT Security Policies and Standards.

E. Backup, Restore and Business Continuity

1. System Administrators must:
 - a) Adhere to the RTOs and RPOs of the agreed-upon Disaster Recovery Plan and Business Continuity Plan established by the HIT Business Continuity Office and Disaster Recovery Policy and Standard.
 - b) Follow the Backup and Recovery Policy for servers they are responsible for.

F. Decommissioning

1. Servers containing Legally Restricted, Confidential Restricted Access and Internal Information must be destroyed following NIST-800-88 guidelines so that any AAH Information is destroyed or rendered unreadable.
2. System administrators must follow the department or division's documented process to decommission servers as needed.

V. **PROCEDURE**

Not applicable

VI. CROSS REFERENCES

- A. AAH Information Classification Policy
- B. AAH HIT Security and Risk Management Policy
- C. AAH Electronic Systems Account Management Policy
- D. AAH Vulnerability Management Standard
- E. AAH HIT Hardware Asset Management (HAM) Policy & Standard
- F. AAH Health Informatics & Technology Disaster Recovery Planning
- G. AAH HIT Logging and Retention Standard

VII. RESOURCES AND REFERENCES

HIPAA	164.308(a)(7), 164.308(a)(4), 164.312(a)(1), 164.312(e)(1), 164.312(d), 164.312(b)
NIST CSF	ID.AM-1, ID.AM-2, ID.AM-3, PR.IP-1, PR.IP-4, PR.IP-8, PR.PT-1, PR.PT-2, PR.PT-3, PR.DS-1, PR.DS-2, PR.DS-3, PR.DS-6, PR.DS-7
PCI DSS 3.2.1	2.1, 2.2, 5.1, 6.1,6.2, 6.4.5, 9.5, 10, 11.5, & 12.10
HITRUST CSF v8.1	01.l, 06.f, 07.b, 09.d, 09.l, 09.p, 09.r, 09.aa, 09.ab, 09.af, 10.b,
CIS Critical Security Controls	01, 3, 4, 5, 6, 8, 9, 13, 14
Time Protocols	https://tools.ietf.org/html/rfc5905 https://tools.ietf.org/html/rfc1305

VIII. ATTACHMENT

Not applicable